MAHMUD HASAN SIZAN

OFFENSIVE SECURITY RESEARCHER · AI-AUGMENTED PENETRATION TESTING · ATTACK SURFACE MANAGEMENT · SECURITY AUTOMATION

twistedmock@wearehackerone.com

LinkedIn profile

twistedmock.com

github.com/Twistedmock

Cumilla, Bangladesh GMT+6 · remote or relocating

HackerOne · Bugcrowd profiles

PROFILE

Bug bounty hunter on **HackerOne**, **Bugcrowd** and **Intigriti** since 2020, with six years of offensive security work behind me: **top 500 all-time on HackerOne at #476**, with **5,987 reputation**, **HackerOne Clear** (background-checked), and **200+ valid vulnerabilities** reported to **100+ organisations**, with public credits from **Apple**, **Google**, **Microsoft**, **Goldman Sachs**, **SpaceX** and **GitHub**. I work heavily with AI: the agent harnesses I have built around **Claude** and **Codex** run reconnaissance, triage and reporting for me, and I bring that same AI-augmented approach to penetration testing, red teaming and attack surface management.

CORE STRENGTHS

AI-augmented offensive security

Personal Claude and Codex agent harnesses wired to my own tooling — reconnaissance, triage, proof-of-concept drafting and reporting at a scale one tester cannot reach by hand, with every exploitation step steered by me.

Web application penetration testing

Injection, broken authentication, XML external entities, broken access control, security misconfiguration and cross-site scripting — each confirmed by a HackerOne badge — plus sensitive data exposure, SSRF, open redirect and insecure-design flaws.

Attack surface management & reconnaissance

Internet-wide asset discovery, subdomain and port intelligence and continuous monitoring across Shodan, Censys, crt.sh, Whoxy and Crunchbase — mapping an estate without touching it.

Security automation & tooling

Rust, Python and Bash; open-source qshodan and qport; an attack surface monitoring SaaS in development.

Reporting & communication

Clear reproduction steps, impact framing and remediation guidance that mature security teams accept and pay for; fluent English (IELTS Academic 8.0).

Breadth of targets

Consumer platforms, fintech and banking, government, aviation, telecoms and open-source infrastructure — public credits listed below.

PROFESSIONAL EXPERIENCE

Bug Bounty Hunter — HackerOne, Bugcrowd, Intigriti | Remote | 2020 – Present

- **200+ valid vulnerabilities** reported to **100+ organisations** across the platforms; top 500 all-time on HackerOne (#476); 134 reports resolved and 196 paid bounties; HackerOne Clear; Community Milestone Level III; valid reports every month of 2026 so far.
- **Public acknowledgements: Apple** (web server security — three times, most recently February 2026), **Goldman Sachs** (bounties, 2026), **GitHub** (Security Researcher), **Adobe**, **UNESCO** (June 2025), **Deutsche Telekom**, **Achmea**, **ShopClues**; hall of fame at **Google**, **Microsoft**, **Samsung**, **Accenture** and the **Dutch government**.
- **Public programs** include PayPal, Palantir, Databricks, Spotify, Roblox, UPS, Xiaomi, AT&T, Kubernetes, Epic Games, Polygon, Hilton, Hyatt, Veeam, Stellar and the U.S. GSA; **Bugcrowd hall of fame** at SpaceX/Starlink, Atlassian, Twilio, Bitdefender, Coca-Cola, United Airlines, Lenovo, Ibotta, Monash University and the U.S. Department of Veterans Affairs.
- Many of the programs I work with are **private and invitation-only**; they are not named here, as their terms require.
- Findings range from account takeover and access-control flaws to SSRF, XXE and injection, on targets from consumer applications to financial and government systems — each delivered as a report the program could reproduce and fix.

AI & DEVELOPMENT EXPERIENCE

Developer *2022 – Present*

- **Claude / Codex agent harnesses** — personal agentic pipelines wired to my reconnaissance stack: scope ingestion, asset discovery, vulnerability triage, proof-of-concept drafting and report writing, with a human in the loop for every exploitation decision. The core of how I work today.
- **Attack Surface Monitoring** — an enterprise-grade **SaaS** (in development) folding Crunchbase, Shodan, Censys, Whoxy and crt.sh into one continuous picture of an organisation's attack surface, with custom reconnaissance on top; built to connect security researchers with businesses for penetration testing, red teaming and vulnerability hunting.
- **qshodan** (Rust, open source) — extracts hosts from Shodan and defeats its 1,000-result ceiling by recursively subdividing the search until every bucket fits; validates, strips reserved ranges, deduplicates. github.com/Twistedmock/qshodan
- **qport** (Rust, open source) — port discovery from Shodan's InternetDB at hundreds of requests a second, so an entire estate can be mapped without a packet reaching the asset owner. github.com/Twistedmock/qport
- Custom workflows and tools in **Bash, Python and Rust** for reconnaissance, attack surface monitoring, mass vulnerability detection and exploitation.

AWARDS & RECOGNITION

* Top 10 hackers on the HackerOne Bangladesh leaderboard (2021–2026) — currently first
* Top 500 all-time on HackerOne, at #476 · HackerOne Clear (background-checked) · Community Milestone Level III (2025–26)
* GitHub Security Researcher badge
* Invitation to the Microsoft Security Conference 2024–2025
* Swag from John Deere, Achmea, Microsoft and GitHub for responsible disclosure

EDUCATION

Higher Secondary Certificate

Ispahani Public School & College [01/07/2017 – 01/06/2020] SCIENCE GPA 5.00
Cumilla Cantonment, Cumilla

Secondary School Certificate

Miah Bazar Latifunnesa High School [01/01/2016 – 30/03/2017] SCIENCE GPA 5.00
Miah Bazar, Chauddagram, Cumilla

Penetration Testing Courses

Udemy, Coursera, YouTube, online platforms [01/01/2020 – current]

- Networking, Linux, OWASP Top 10, API security; Bash, Python, Rust, Git, GitHub, Notion
- Reconnaissance, attack surface management, web application hacking; database management; cloud (Amazon, Google, Microsoft)
- Leadership and team management; organisation and effective time management

PERSONAL

- Languages: **English** — fluent (IELTS Academic 8.0, 2024); **Bengali** — native; **Hindi** and **Urdu** — conversational (speaking and listening).
- Volunteer with APON, a community organisation: leading outreach programmes, donating blood regularly and fundraising for the poor, sick and marginalised in my community.

HOBBIES / INTERESTS

- Enjoy nurturing indoor plants and spending time in nature.
- Fond of cats, pigeons and birds.
- Enjoy swimming, hiking, cycling and working out at the gym.
- Love reading books and watching films.
